

Manual 41 — Implementação Controlada de UK GDPR / Data Protection Act

****Linha de base controlada:**** UK GDPR e Data Protection Act 2018 conforme alterada pela Data (Use and Access) Act 2025, sujeita a reverificação legislativa no release.

****Limite:**** texto legal, PECR quando aplicável, códigos/guidance do ICO, deveres setoriais, contratos e práticas internas permanecem camadas distintas.

****Regra de release:**** reverificar legislação vigente e material de implementação do ICO no congelamento do candidato.

Chapter 01 — Propósito, escopo e hierarquia de fontes

Defina hierarquia legal controlada, método de aplicabilidade, owners, change watch e índice de evidência. Não apresente guidance do regulador como texto legal.

Chapter 02 — Aplicabilidade e alcance territorial

Determine aplicabilidade considerando estabelecimento, targeting, monitoring, isenções e fatos transfronteiriços. Registre fundamentos de inclusão/exclusão.

Chapter 03 — Papéis controller, processor e joint controller

Atribua papéis conforme propósitos, meios, instruções e relações reais. Mantenha assessments, contratos, arranjos conjuntos e gatilhos de revisão.

Chapter 04 — Accountability e governança

Atribua responsabilidades executivas, DPO/privacy, jurídico, security, records, procurement, product, RH e operações. Mantenha políticas, decisões, riscos, issues e management review.

Chapter 05 — Records of processing e inventário

Mantenha registros de processing, sistemas, purposes, categorias, data subjects, recipients, transfers, retention, lawful bases, medidas e owners.

Chapter 06 — Lawful bases

Exija decisão documentada antes de processar. Distinga contract, legal obligation, vital interests, public task, legitimate interests, consent e outras condições aplicáveis.

Chapter 07 — Legitimate interests e recognized legitimate interests

Documente rota aplicável, propósito, necessidade, balancing ou condições legais, safeguards, transparency, objections e triggers. Não combine rotas legais distintas.

Chapter 08 — Governança do consentimento

Quando consent for utilizado, assegure validade contextual e mantenha captura, granularidade, evidência, withdrawal, refresh e suppression downstream.

Chapter 09 — Transparência e privacy information

Forneça informação clara e acessível sobre processing, purposes, bases, recipients, transfers, retention, rights, complaints e automated processing relevante.

Chapter 10 — Purpose limitation e data minimization

Limite coleta/uso a propósitos documentados e dados apropriados. Governe secondary use, compatibility analysis e exceções.

Chapter 11 — Accuracy e data quality

Defina controles de qualidade, correction, source reliability, propagação de mudanças e monitoring proporcional ao risco.

Chapter 12 — Retention, deletion e archival

Mantenha regras baseadas em requisitos legais, regulatórios, contratuais, records, litigation e operacionais. Execute deletion defensável e exceções controladas.

Chapter 13 — Security of processing

Implemente medidas administrativas, técnicas e organizacionais proporcionais ao risco: identity/access, encryption, resilience, logging, vulnerability management, recovery e assurance.

Chapter 14 — Processor e contract governance

Selecione processors por due diligence e mantenha instructions, confidentiality, security, subprocessors, assistance, deletion/return, audit e incident obligations.

Chapter 15 — International transfers

Identifique restricted transfers e documente mechanism, assessment, safeguards, supplementary measures, exceptions, onward controls e monitoring aplicáveis.

Chapter 16 — Subject access requests

Controle intake, identity/authority, search, exemptions, third-party balancing, response, secure delivery, timing, escalation e evidence retention.

Chapter 17 — Rectification, erasure e restriction

Defina workflows para correction, deletion e restriction, incluindo recipient notification, exceptions, legal holds, execução técnica e closure evidence.

Chapter 18 — Objection rights

Avalie objections conforme processing basis/context, incluindo direct marketing. Mantenha decisions, suppression, escalation e implementação downstream.

Chapter 19 — Data portability

Determine quando aplica e entregue dados em formato estruturado apropriado com controles seguros. Documente exclusions e delivery evidence.

Chapter 20 — Automated decision-making e profiling

Identifique processos solely automated/materialmente significativos, condições legais/safeguards, transparency, human intervention, challenge, testing e monitoring.

Chapter 21 — Children e pessoas que exigem manejo especial

Aplique controles adequados de idade, capacidade, vulnerabilidade, service/context, transparency, authority, risk e safeguarding sem assumir limiar universal.

Chapter 22 — Special-category e criminal-offence data

Documente condições aplicáveis, requisitos DPA/Schedule, policy documents quando pertinente, access restrictions, minimization, retention e heightened assurance.

Chapter 23 — DPIAs e high-risk processing

Faça screening antes de launch/mudança material. Mantenha scope, necessity/proportionality, risks, measures, residual risk, consultation, approval e review triggers.

Chapter 24 — Personal-data breach response

Integre detection, containment, evidence preservation, risk assessment, notification decisions, communications, processor coordination, remediation e breach records.

Chapter 25 — Complaints e regulator engagement

Mantenha intake, investigation, response, escalation, corrective action, regulator correspondence, legal review e preservação de evidência.

Chapter 26 — PECR e electronic communications boundary

Avalie cookies, tracking, direct marketing e communications separadamente de UK GDPR. Mantenha consent/exemption logic, settings, suppression e change watch.

Chapter 27 — Research, statistics e public-interest overlays

Documente bases, safeguards, compatibility, minimization, access, transparency, exemptions, governance e disclosure limits aplicáveis.

Chapter 28 — Training e role competence

Forneça training baseado em função para handlers, rights teams, engineering, marketing, RH, procurement, security, executives e incident personnel. Mantenha completion/competency evidence.

Chapter 29 — Assurance e audit

Teste notices, lawful bases, rights, contracts, transfers, DPIAs, security, breaches, retention e automated processing com amostras baseadas em risco. Feche findings com evidência.

Chapter 30 — Métricas e management review

Acompanhe rights timeliness, complaints, breaches, DPIA backlog, transfers, processor findings, retention exceptions, training, remediation e legal change. Registre decisões.

Chapter 31 — Localização, provenance e evidência de release

Congele candidatos EN/es-419/pt-BR; vincule DOCX/PDF a SHA-256 e preserve source-version, structure, parity, accessibility, render, workflow-security e staging evidence.

Chapter 32 — Roadmap e reverificação no release

Implemente applicability/inventory; governance/bases; transparency/rights; processors/transfers; security/breaches; high-risk/automated processing; assurance/improvement. Antes de publicar reverifique UK GDPR, DPA 2018, estado DUAA 2025, PECR quando alegado e ICO aplicável. Publicação sequencial após o Manual 40.